

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-17 07:00 WIB

Top 5 Highlights

- Funnel Builder Flaw Under Active Exploitation Enables WooCommerce Checkout Skimming
- Microsoft rejects critical Azure vulnerability report, no CVE issued
- Russian hackers turn Kazuar backdoor into modular P2P botnet
- [+24h Old] Popular node-ipc npm package compromised to steal credentials
- [+24h Old] Avada Builder WordPress plugin flaws allow site credential theft

Threat Intelligence (10)

01. Funnel Builder Flaw Under Active Exploitation Enables WooCommerce Checkout Skimming

Researchers reported active exploitation of a Funnel Builder WordPress plugin flaw to inject JavaScript skimmers into WooCommerce checkout flows and steal payment data.

Why it matters: Checkout skimming campaigns directly monetize compromised sites and can rapidly impact large numbers of customers when popular plugins are targeted.

Recommendation: Update/patch the affected plugin immediately, review checkout templates for injected scripts, and monitor for suspicious outbound connections and webshell indicators.

Sources: <https://thehackernews.com/2026/05/funnel-builder-flaw-under-active.html> | <https://www.bleepingcomputer.com/news/security/funnel-builder-wordpress-plugin-bug-exploited-to-steal-credit-cards/>

02. [+24h Old] TeamPCP releases 'vibe coded' Shai-Hulud source code, issues challenge

Researchers reported a release of 'Shai-Hulud' source code (a variant used in recent supply-chain activity), along with an associated challenge, increasing the likelihood of copycat tooling and derivatives.

Why it matters: Public release of attacker tooling can accelerate commoditization and broaden the set of actors capable of repeating similar campaigns.

Recommendation: Increase scrutiny of software supply-chain inputs (SCA/SBOM), pin dependencies, and hunt for indicators tied to known Shai-Hulud/TanStack-related activity.

Sources:

<https://www.scworld.com/news/teampcp-releases-vibe-coded-shai-hulud-source-code-issues-challenge>

03. [+24h Old] 10.0 Cisco Catalyst SD-WAN Controller bug added to CISA's KEV list

A maximum-severity Cisco Catalyst SD-WAN Controller issue was added to CISA's Known Exploited Vulnerabilities (KEV) catalog, signaling credible exploitation risk.

Why it matters: KEV additions typically correlate with real-world exploitation and should drive urgent remediation for internet-facing and high-privilege systems.

Recommendation: Patch/mitigate immediately, restrict management access, verify MFA and admin controls, and review logs for authentication bypass and anomalous administrative actions.

Sources:

<https://www.scworld.com/news/10-0-cisco-catalyst-sd-wan-controller-bug-added-to-cisas-kev-list>

04. [+24h Old] Researchers bypass Apple's M5 security with AI-powered macOS exploit

Researchers described an AI-assisted exploit chain against macOS on Apple's M5 platform, combining multiple techniques and vulnerabilities to achieve a working exploit.

Why it matters: AI-assisted exploit development can shorten time-to-weaponization, raising pressure on patch velocity and defensive telemetry.

Recommendation: Maintain rapid macOS patching, enable platform hardening controls, and prioritize endpoint visibility for exploit behavior (privilege escalation, persistence attempts, and unusual process injection).

Sources:

<https://www.scworld.com/brief/researchers-bypass-apples-m5-security-with-ai-powered-macos-exploit>

05. [+24h Old] U.S. officials discard items from China trip over security concerns

Reports described heightened operational security measures during U.S. officials' travel, including discarding devices and gifts due to potential surveillance or compromise concerns.

Why it matters: Travel OPSEC incidents and supply-chain risks can lead to credential theft or persistent compromise, especially for high-value targets.

Recommendation: Use travel-specific devices, enforce strong device hardening and account controls, and perform post-travel forensics and credential rotation for high-risk trips.

Sources: <https://www.scworld.com/brief/u-s-officials-discard-items-from-china-trip-over-security-concerns>

06. [+24h Old] ESET details new Ghostwriter activity targeting Ukrainian government

ESET reported new Ghostwriter-related activity targeting Ukrainian government entities via spear-phishing emails with a PDF lure, aligned to the FrostyNeighbor campaign.

Why it matters: Targeted phishing remains a primary initial access vector for espionage operations and often precedes credential theft or follow-on malware deployment.

Recommendation: Harden email security (attachment scanning/sandboxing), enforce MFA, and run targeted hunts for campaign-specific indicators in mail gateways and endpoint telemetry.

Sources:

<https://www.scworld.com/brief/eset-details-new-ghostwriter-activity-targeting-ukrainian-government>

07. [+24h Old] Microsoft Exchange, Windows 11 hacked on second day of Pwn2Own

On day two of Pwn2Own Berlin 2026, researchers demonstrated multiple zero-day exploits across platforms including Windows 11 and Microsoft Exchange, earning significant payouts.

Why it matters: Pwn2Own results provide early warning of impactful vulnerability classes that may be patched soon and later targeted by adversaries.

Recommendation: Track upcoming vendor patches, prioritize remediation for exposed services, and review compensating controls (EDR, attack surface reduction rules, and network segmentation).

Sources: <https://www.bleepingcomputer.com/news/security/pwn2own-day-two-hackers-demo-microsoft-exchange-windows-11-red-had-enterprise-linux-zero-days/>

08. [+24h Old] TanStack Supply Chain Attack Hits Two OpenAI Employee Devices, Forces macOS Updates

OpenAI disclosed that two employee endpoints were impacted via a TanStack-related supply-chain event, prompting macOS updates; the company reported no impact to user data or production systems.

Why it matters: Supply-chain compromises can bypass perimeter defenses and directly reach developer workstations and build pipelines.

Recommendation: Adopt dependency pinning and verification, monitor for anomalous package behavior, and enforce least-privilege and token hygiene in developer environments.

Sources: <https://thehackernews.com/2026/05/tanstack-supply-chain-attack-hits-two.html>

09. [+24h Old] China-Linked Hackers Deploy New TencShell Malware Against Global Manufacturer

A suspected China-linked actor targeted a manufacturer using new 'TencShell' tooling and webshell-style tradecraft, highlighting ongoing investment in stealthy post-compromise capabilities.

Why it matters: Webshell and modular backdoor activity can lead to long dwell time, data theft, and repeated access even after initial remediation.

Recommendation: Hunt for webshell indicators, audit exposed web applications, rotate credentials after suspected compromise, and deploy file integrity monitoring for web directories.

Sources: <https://www.infosecurity-magazine.com/news/china-hackers-tencshell-malware/>

10. [+24h Old] Taiwan Bullet Train Hack Highlights Cybersecurity Gaps in Rail Systems

A rail disruption incident in Taiwan highlighted how security gaps in operational technology (OT) environments can translate into real-world service disruption and safety concerns.

Why it matters: Transportation OT environments often have long asset lifecycles and limited monitoring, making them attractive for disruption-oriented threat activity.

Recommendation: Prioritize OT network segmentation, deploy OT-aware monitoring, and validate incident response playbooks with rail/ICS stakeholders.

Sources: <https://www.darkreading.com/ics-ot-security/taiwan-incident-highlights-cybersecurity-gaps>

Latest Vulnerabilities (10)

01. Microsoft rejects critical Azure vulnerability report, no CVE issued

A researcher alleged Microsoft quietly fixed a critical Azure Backup for AKS issue after rejecting the report and without assigning a CVE; Microsoft disputed the claim and said the behavior was expected.

Why it matters: Disputed or quietly fixed cloud issues can still leave organizations exposed if they rely on assumptions about default security controls.

Recommendation: Review Azure Backup for AKS configurations, validate least-privilege access, and monitor audit logs for unexpected backup/restore activity or privilege

escalation paths.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-rejects-critical-azure-vulnerability-report-no-cve-issued/>

02. CVE-2026-8759 | xiandafu beetl up to 3.20.2 SpELFunction SpELFunction.java expression language injection (EUVD-2026-30704)

A critical expression-language injection issue was reported in xiandafu beetl up to 3.20.2, potentially enabling attackers to execute attacker-controlled expressions in affected environments.

Why it matters: Expression injection vulnerabilities can lead to remote code execution or sensitive data access in server-side applications.

Recommendation: Identify affected deployments, upgrade to a patched release, and add WAF rules/validation to block malicious expression payload patterns.

Sources: <https://vuldb.com/vuln/364386>

03. CVE-2026-8758 | Metasoft MetaCRM up to 6.4.0 Beta06 upload3.jsp unrestricted file upload (EUVD-2026-30705)

A critical unrestricted file upload vulnerability was disclosed in Metasoft MetaCRM (up to 6.4.0 Beta06), which could enable arbitrary file upload and potential server compromise.

Why it matters: Unrestricted upload issues are commonly weaponized to gain remote execution (webshells) and persistent access.

Recommendation: Patch/upgrade immediately, restrict access to upload endpoints, and monitor web directories for unexpected file creation and execution.

Sources: <https://vuldb.com/vuln/364385>

04. CVE-2026-8757 | adenhq hive up to 0.11.0 routes_sessions.py path traversal (EUVD-2026-30703)

A critical path traversal vulnerability was reported in adenhq hive up to 0.11.0, potentially allowing unauthorized file access via crafted requests.

Why it matters: Path traversal can expose credentials, configuration files, and secrets that enable follow-on compromise.

Recommendation: Upgrade to a fixed version, apply request validation, and review logs for suspicious traversal patterns (e.g., ../ sequences and encoded variants).

Sources: <https://vuldb.com/vuln/364384>

05. CVE-2026-8756 | fishaudio Bert-VITS2 Gradio generate_config data_dir path traversal (EUVD-2026-30702)

A critical path traversal flaw was disclosed in fishaudio Bert-VITS2 affecting a Gradio interface component, potentially allowing attackers to access files outside intended directories.

Why it matters: AI/ML web UIs are increasingly deployed internally and externally; traversal flaws can expose models, secrets, and system files.

Recommendation: Patch the affected build, restrict exposure of Gradio endpoints, and enforce authentication and network controls for ML tooling.

Sources: <https://vuln.com/vuln/364383>

06. CVE-2026-8755 | fishaudio Bert-VITS2 hiyoriUI.py _get_all_models path traversal (EUVD-2026-30701)

A critical path traversal vulnerability in fishaudio Bert-VITS2 was reported that could permit unauthorized access to files by manipulating model-related paths.

Why it matters: Traversal vulnerabilities can enable data theft and may serve as a stepping stone to broader compromise.

Recommendation: Update to a fixed version, review deployment exposure, and add defense-in-depth controls (authn, reverse proxy restrictions, and filesystem permissions).

Sources: <https://vuln.com/vuln/364382>

07. CVE-2026-8754 | AstrBot up to 4.23.5 file upload filename path traversal (EUVD-2026-30700)

A critical path traversal issue was identified in AstrBot (up to 4.23.5) in a file upload handler, potentially enabling attackers to write or access files outside intended paths.

Why it matters: Traversal and unsafe upload handling can lead to webshell deployment and full server compromise.

Recommendation: Patch immediately, validate and normalize upload paths, and monitor for anomalous uploads and unexpected file writes.

Sources: <https://vuln.com/vuln/364381>

08. CVE-2026-8753 | Kodbox up to 1.64 ffmpegBin command injection (EUVD-2026-30698)

A critical command injection vulnerability was reported in Kodbox up to 1.64, related to video thumbnail processing and ffmpeg binary invocation.

Why it matters: Command injection often results in remote code execution, enabling rapid compromise of file management servers.

Recommendation: Upgrade to a patched version, restrict exposure of media processing endpoints, and monitor for suspicious process execution and child processes spawned by the application.

Sources: <https://vuln.com/vuln/364380>

09. CVE-2026-8752 | h2oai h2o-3 Rapids AstSetProperty.java exec access control (EUVD-2026-30699)

A critical security issue in h2oai h2o-3 (up to 7402) was disclosed affecting Rapids property setting and access control, potentially enabling unauthorized execution paths.

Why it matters: Weak access control and unsafe execution primitives in analytics platforms can enable data theft and lateral movement in high-value environments.

Recommendation: Apply vendor patches, restrict network access to administrative APIs, and review role-based access controls for Rapids usage.

Sources: <https://vuldb.com/vuln/364379>

10. CVE-2026-8751 | h2oai h2o-3 Model.java importBinaryModel deserialization (EUVD-2026-30697)

A critical deserialization issue was reported in h2oai h2o-3 (up to 7402) involving binary model import, which could enable code execution in certain deployment scenarios.

Why it matters: Deserialization vulnerabilities can allow remote code execution and are frequently exploited when untrusted data reaches vulnerable endpoints.

Recommendation: Upgrade to patched versions, disable or restrict model import endpoints, and ensure untrusted inputs cannot reach deserialization paths.

Sources: <https://vuldb.com/vuln/364378>

Data Breach & Cybercrime (10)

01. Russian hackers turn Kazuar backdoor into modular P2P botnet

A Russia-linked actor evolved the long-running Kazuar backdoor into a modular peer-to-peer botnet to improve stealth, persistence, and data collection across compromised networks.

Why it matters: Modular P2P malware complicates takedown and can support long-term espionage or monetization through credential theft and secondary compromise.

Recommendation: Hunt for Kazuar-related artifacts, monitor DNS and unusual peer-to-peer traffic, and rotate credentials/tokens if systems are suspected of compromise.

Sources: <https://www.bleepingcomputer.com/news/security/russian-hackers-turn-kazuar-backdoor-into-modular-p2p-botnet/> | <https://thehackernews.com/2026/05/turla-turns-kazuar-backdoor-into.html>

02. [+24h Old] Popular node-ipc npm package compromised to steal credentials

Newly published node-ipc versions were compromised with an infostealer that exfiltrates cloud and developer secrets (AWS/Azure/GCP/OCI keys, CI/CD tokens, SSH keys, .env files) using DNS TXT queries for data exfiltration.

Why it matters: Developer and CI/CD credential theft can cascade into broader compromise, including cloud account takeover and supply-chain insertion into downstream software.

Recommendation: Remove affected versions, audit lockfiles and npm caches, rotate all potentially exposed secrets, and implement dependency integrity controls and anomaly detection for build environments.

Sources: <https://www.bleepingcomputer.com/news/security/popular-node-ipc-npm-package-compromised-to-steal-credentials/>

03. [+24h Old] Avada Builder WordPress plugin flaws allow site credential theft

Two Avada Builder WordPress plugin vulnerabilities (including arbitrary file read and SQL injection conditions) could allow attackers to extract sensitive data and potentially

achieve site takeover on impacted installations.

Why it matters: Credential and configuration exposure from high-install-base plugins can enable mass compromise, admin takeover, and downstream customer data theft.

Recommendation: Update Avada Builder to a fully patched version, review logs for suspicious access patterns, and rotate WordPress/database credentials if exposure is suspected.

Sources: <https://www.bleepingcomputer.com/news/security/avada-builder-wordpress-plugin-flaws-allow-site-credential-theft/>

04. [+24h Old] Attackers replaced JDownloader installer downloads with malware

Attackers were reported to have swapped or replaced JDownloader installer downloads with malware, using a trusted distribution channel to improve victim success rates.

Why it matters: Trojanized installers are a reliable initial access vector that can lead to credential theft, ransomware, or secondary payload deployment.

Recommendation: Verify installers using official sources and signatures, monitor endpoint telemetry for suspicious installer behavior, and block unknown binaries via application allowlisting where feasible.

Sources: <https://www.malwarebytes.com/blog/news/2026/05/attackers-replaced-jdownloader-installer-downloads-with-malware>

05. [+24h Old] Hackers use PyInstaller to hide XWorm malware

Reports described attackers leveraging PyInstaller to package and obfuscate XWorm malware, complicating static analysis and improving delivery success.

Why it matters: Commodity malware families continue to adopt developer tooling to evade detection and accelerate distribution.

Recommendation: Improve detection for packed executables, monitor unusual Python runtime usage on endpoints, and strengthen email/web filtering against common malware delivery vectors.

Sources: <https://www.scworld.com/brief/hackers-use-developer-tool-to-hide-xworm-malware>

06. [+24h Old] FTC begins enforcing Take It Down Act for nonconsensual deepfakes

The FTC began enforcing the Take It Down Act, requiring online platforms to remove nonconsensual intimate imagery and AI-generated 'digital forgeries' within defined timelines.

Why it matters: Regulatory enforcement shapes incident response obligations for platforms and can drive new abuse reporting, takedown, and moderation workflows.

Recommendation: Review trust-and-safety processes, improve abuse reporting and takedown SLAs, and strengthen identity verification and content integrity controls.

Sources:

<https://www.scworld.com/brief/ftc-begins-enforcing-take-it-down-act-for-nonconsensual-deepfakes>

07. [+24h Old] Welcome to BlackFile: Inside a Vishing Extortion Operation

Google Threat Intelligence Group detailed an extortion campaign involving vishing (voice phishing) by UNC6671, including operational patterns and tactics used to pressure victims.

Why it matters: Vishing-based extortion bypasses many technical controls and targets human workflows, often leading to rapid credential compromise or fraudulent fund transfers.

Recommendation: Implement call-back verification procedures, train staff on vishing scenarios, enforce MFA resistant to social engineering, and monitor for unusual helpdesk or account recovery activity.

Sources: <https://cloud.google.com/blog/topics/threat-intelligence/blackfile-vishing-extortion-operation/>

08. [+24h Old] American Lending Center Data Breach Affects 123,000 Individuals

A lending company disclosed that a ransomware incident affected roughly 123,000 individuals, with notification following investigation into what data was accessed.

Why it matters: Financial-sector breaches can trigger identity fraud risks and provide attackers with data that enables targeted phishing and account takeover.

Recommendation: Validate incident response and backup readiness, rotate credentials, monitor for misuse of exposed data, and implement enhanced fraud monitoring for impacted populations.

Sources:

<https://www.securityweek.com/american-lending-center-data-breach-affects-123000-individuals/>

09. [+24h Old] Congress Puts Heat on Instructure After Canvas Outage

Following a cyber incident and outage affecting the Canvas platform, U.S. lawmakers questioned Instructure's handling of the event and the reported interactions with the ShinyHunters group.

Why it matters: Education platforms are high-value targets due to large user bases and sensitive data; outage events can signal underlying data exposure risks.

Recommendation: Review third-party risk and incident communications plans, enforce strong authentication, and validate monitoring for suspicious data access and exfiltration patterns.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/congress-instructure-shinyhunters-attacks>

10. [+24h Old] What 45 Days of Watching Your Own Tools Will Tell You About Your Real Attack Surface

An analysis argued that the highest-risk activity often looks like normal administration (PowerShell, remote management, scripting) and that observing first-party tool usage can reveal hidden exposure.

Why it matters: Living-off-the-land techniques reduce attacker reliance on malware and can evade detection if organizations do not baseline administrative tool usage.

Recommendation: Baseline and monitor administrative tooling (PowerShell/WMIC/remote exec), enforce least privilege and just-in-time access, and build detections around

suspicious command lines and lateral movement patterns.

Sources: <https://thehackernews.com/2026/05/what-45-days-of-watching-your-own-tools.html>